OWASP Top 10 취약점 탐지를 위한 CI/CD 보안 파이프라인 개발*

어윤규*, 김태현*, 김서연*, 남수만**

*청주대학교 (학부생)

**청주대학교 (교수)

Development of a CI/CD Security Pipeline for Detecting OWASP Top 10 Vulnerabilities

Yun Gyu Eo*, Tae Hyun Kim*, Seo Yeon Kim*, Su Man Nam**

*Cheongju University (Undergraduate student)

*Cheongju University (Professor)

요 약

CI/CD 파이프라인의 보안 자동화 수요가 증가함에 따라, 정적 분석 기반 취약점 탐지의 중요성이 부각되고 있다. GitHub Actions와 통합된 CodeQL은 CI/CD 보안 도구로 널리 활용되지만, 데이터 흐름 추적 중심의 구조적 특성으로 인해 OWASP Top 10(2025)의 일부 항목 탐지가 제한적이다. 본 논문은 AST 파싱과 패턴 매칭을 결합한 자체 분석 엔진을 CI/CD 파이프라인에 통합하여 OWASP Top 10(2025)을 탐지하는 보안 파이프라인을 제안한다.

I. 서론

CI/CD(Continuous Integration & Continuous Deployment) 파이프라인은 소스 코드를 작성한 후 사용자에게 소프트웨어를 배포하기까지 모든 단계를 자동화하는 프로세스이다. 일반 CI/CD는 코드 빌드부터 배포까지 자동화를 지향하지만, 소크 코드 취약점을 자동으로 식별하는 것은 어려움이 있다. 특히, Github Action 기반 CodeQL은 정적 분석을 제공하지만 데이터 흐름 추적 중심의 구조적 특성으로 OWASP Top10(2025)의 일부 항목은 탐지가 어렵다[1, 2].

본 논문은 자체 개발한 CI/CD 엔진을 통해 AST 파싱과 패턴 매칭을 결합하여 OWASP Top 10(2025)의 항목을 탐지하는 보안 파이프라인을 제안한다. 제안 CI/CD 보안 파이프라인에서는 OWASP Juice Shop[3] 환경에 주요 CWE 별 취약점 코드를 삽입하여 실험한 결과, 10개 항목을 성공적으로 탐지한다.

주요 기여는 다음과 같다. AST 파싱과 패턴 매칭을 결합한 자체 분석 알고리즘을 통해 OWASP Top 10(2025) 전 항목 탐지를 목표로 하는 CI/CD 보안 파이프라인을 제안하고, OWASP Juice Shop 기반의 통제된 실험 환경 구성 방법론을 제시함으로써 기존 CodeQL 기반 파이프라인 대비 커버리지 우위를 논증한다.

II. 관련 연구 및 배경

2.1 OWASP Top 10 (2025)

OWASP Top 10은 웹 애플리케이션에서 가장 빈번하게 발생하는 보안 위협을 정리한 표준 문서로[4], 2025년판은 A02가 Security Misconfiguration으로 상향되고, A03에 소프트웨어 공급망 보안 위협을 다루는 Software Supply Chain Failures가 신규 편입되었으며, A10은 Mishandling of Exceptional

* 본 과제(결과물)는 2025년도 교육부 및 충청북도의 재원으로 충북RISE센터의 지원을 받아 수행된 지역혁신중심 대학지원체계(RISE)의 결과입니다.(2025-RISE-11-013-02)

Conditions로 교체되는 등 2021년 대비 주목할 만한 구성 변화를 포함한다[4]. OWASP는 각 항목에 대해 복수의 CWE[5]를 공식 매핑으로 제공하며, 본 논문은 이를 기반으로 각 항목의 대표적인 CWE를 1개씩 선정하여 탐지 분석을 평가한다.

2.2 CodeQL 활용 CI/CD

CodeQL[6]은 GitHub가 개발한 정적 분석 엔진으로, 소스 코드를 관계형 데이터베이스 형태로 변환한 뒤 QL(Query Language)을 통해 취약점을 탐지하며, GitHub Actions와 통합되어 CI/CD 보안 파이프라인으로 활용한다. 이 도구는 오염 전파(Taint Propagation)와 데이터 흐름 분석을 핵심으로 분석하고[1], 국내에서도 오픈소스 구성요소 분석(SCA) 등 소프트웨어 공급망 보안 영역에 적용되고 있다[7]. 그러나 CodeQL의 기본 쿼리 라이브러리는 데이터 흐름으로 추적 가능한 취약점 유형에 집중되어 있어 OWASP Top 10(2025)의 전 항목 검사가 어렵다[8]. 예컨대, A01(CWE-284)의 권한 체크 로직 부재, A02(CWE-1104)의 보안 설정 하드코딩, A03(CWE-829)의 미검증 외부 경로 동적 로딩, A06(CWE-703)의 빈 예외 처리 구현은 소스코드의 구조적, 설계적 결함에 해당하여 데이터 흐름 추적만으로는 탐지하기 어렵다[1, 8]. 선행 연구에서도 단일 SAST 도구만으로는 전 항목 커버가 어려워 보완 접근법이 필요함이 지적된 바 있다[2, 8].

III. 제안 CI/CD 보안 파이프라인

3.1 파이프라인 아키텍처

본 논문은 OWASP Top 10(2025) 항목의 탐지를 목표로 하는 CI/CD 보안 파이프라인을 제안한다. 제안 파이프라인은 기존 파이프라인과 달리, 자체 분석 엔진을 통해 AST 파싱과 패턴 매칭을 결합하여 데이터 흐름 분석뿐만 아니라, 취약점 패턴까지 탐지한다. 제안 파이프라인은 코드 변경이 GitHub 저장소에 반영되는 시점에 자동으로 실행되며, Clone → Install & Test → Security Scan → Build → Deploy 순서로 동작한다. Security Scan 단계에서 자체 분석 엔진이 OWASP Top 10(2025) 각 항목의 대표 CWE 탐지 알고리즘을 순차적으로 적용하고, 탐지 결과에 대해 LLM 기반 자연어 보고서 생성 기능을 추가 구성할 수 있다.

3.2 탐지 알고리즘

그림 1은 자체 파이프라인 Security Scan 단계의 취약점 탐지 알고리즘 흐름도이다.

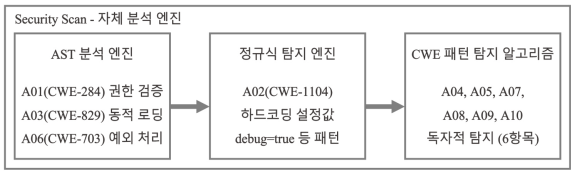


그림 1. Security Scan 탐지 알고리즘 흐름도

제안 엔진은 소스코드를 AST로 파싱하여 구문 구조를 추출한 뒤, CWE별로 사전 정의된 취약 패턴을 AST 노드에 매칭하는 방식으로 탐지를 수행한다. A01(CWE-284)은 라우트 핸들러 AST 노드에서 권한 검증 함수 호출 패턴의 존재 여부를 검사하여 미탐지 핸들러를 식별하고, A02(CWE-1104)는 설정 노드에서 debug=true 등 민감한 하드코딩 패턴을 정규식으로 매칭하여 탐지한다[9]. A03(CWE-829)는 동적 로딩 함수 인자가 미검증 외부 URL로부터 유래하는지를 AST 분석으로 추적하며[7], A06(CWE-703)은 catch 블록 내 예외 처리 로직이 부재한 빈 구현 패턴을 AST 분석으로 식별한다. 나머지 6개 항목(A04, A05, A07, A08, A09, A10)에 대해서도 제안 엔진이 독자적으로 탐지할 수 있도록 CWE 패턴 탐지 알고리즘을 설계하여[2], OWASP Top 10(2025) 항목의 전체 탐지를 목표로 한다.

3.3 실험 설계

제안 파이프라인의 탐지 성능을 평가하기 위해 실험 환경은 OWASP Juice Shop[3]을 사용한다. Juice Shop은 TypeScript 기반 Angular 프론트엔드와 Node.js/Express 백엔드로 구성된 의도적 취약점 내장 웹 애플리케이션으로, 소스코드가 완전히 공개되어 있어 연구자가 특정 CWE에 대응하는 취약점 코드를 직접 추가 삽입하고 Ground Truth를 제어하기에 적합하다. 각 대표 CWE[5]에 대응하는 취약점 코드 스니펫을 Juice Shop 소스코드에 의도적으로 추가

삽입하여 실험 환경을 구성했다. 비교 기준인 기존 파이프라인은 GitHub Actions 기반 CodeQL[6]을 security-and-quality 쿼리 스위트로 설정하되, 별도의 커스텀 쿼리 없이 기본 쿼리 라이브러리만을 적용하여 탐지 범위의 한계를 측정한다[1]. 표 1은 기존 파이프라인과 제안 파이프라인의 탐지 결과를 보여준다.

표 1. OWASP Top 10(2025) 항목별 대표 CWE, CodeQL 및 제안 파이프라인 탐지 여부

OWASP 항목	대표 CWE	기존	제안
A01 : Broken Access Control	CWE-284	×	○
A02 : Security Misconfiguration	CWE-1104	×	○
A03 : Software Supply Chain Failures	CWE-829	×	○
A04 : Cryptographic Failures	CWE-327	○	○
A05 : Injection	CWE-79	○	○
A06 : Insecure Design	CWE-703	×	○
A07 : Authentication Failures	CWE-798	○	○
A08 : Software or Data Integrity Failures	CWE-502	○	○
A09 : Security Logging & Alerting Failures	CWE-532	○	○
A10 : Mishandling of Exceptional Conditions	CWE-209	○	○

IV. 결론

본 논문은 GitHub 기반의 CodeQL을 사용하는 기존 방식에서, 자체 CI/CD 엔진을 통해 OWASP Top 10(2025) 전 항목을 탐지할 수 있는 보안 파이프라인을 제안한다. 기존 파이프라인은 소스 코드의 구조적 분석 한계로 인해 OWASP Top 10(2025) 중 6개 항목만 식별한다. 이를 해결하기 위해 본 연구는 AST 파싱과 패턴 매칭을 결합한 자체 탐지 알고리즘을 개발하여 제안 파이프라인에 적용하였다. 제안 파이프라인의 성능 검증을 위해 OWASP Juice Shop 환경에 주요 CWE별 취약점 코드를 삽입하여 실험한 결과, 기존 파이프라인은 6개 항목 탐지에 그친 반면, 제안 파이프라인은 10개 전 항목을 성공적으로 탐지한다. 향후에는 정량적 지표(Precision, Recall)를 바탕으로 탐지 커버리지를 실증하고, 지원 언어 및 애플리케이션 유형을 확대하여 파이프라인의 범용성을 확보할 계획이다.

[참고문헌]

[1] Z. Li, Z. Liu, W. K. Wong, and P. Ma, "Evaluating C/C++ vulnerability detectability of query-based static application security testing tools," in Proc. IEEE, 2024.

[2] F. Mateo Tudela and J. R. Bermejo Higuera, "On combining static, dynamic and interactive analysis security testing tools to improve OWASP Top Ten security vulnerability detection in web applications," Appl. Sci., vol. 10, no. 24, p. 9119, 2020.

[3] OWASP, "OWASP Juice Shop," [Online]. Available: https://owasp.org/www-project-juice-shop/. [Accessed: 2025].

[4] OWASP, "OWASP Top 10:2025," [Online]. Available: https://owasp.org/www-project-top-ten/. [Accessed: 2025].

[5] MITRE, "Common Weakness Enumeration (CWE)," [Online]. Available: https://cwe.mitre.org/. [Accessed: 2025].

[6] GitHub, "CodeQL Documentation," [Online]. Available: https://codeql.github.com/docs/. [Accessed: 2025].

[7] 정윤영, 유승준, 김수연, "SW 공급망 보안을 위한 CodeQL 활용 오픈소스 SCA 제안," 한국정보통신학회 종합학술대회 논문집, vol. 28, no. 2, pp. 114-116, 2024.

[8] 이은영, "보안취약점 탐지를 위한 정적 분석 기법 비교 연구," 한국정보기술학회논문지, vol. 23, no. 2, pp. 241-251, 2025.

[9] 최영해, 노형준, 조성윤 외, "오픈소스 취약점 점검 도구 및 종합 보안 메트릭 설계를 통한 DevSecOps 구축방안 연구," 정보보호학회논문지, vol. 33, no. 4, pp. 699-707, 2023.